

Suricata 7.0.3向けEmerging Threats PRO/OPENルールセットが利用可能になりました

Rich

argonzo

2024年6月

こんにちは！ETチームより、Suricata 7.0.3への正式対応をお知らせいたします。昨晚のルール配信より、既存のルールセットをフォーク（派生）させ、ETPRO（お客様向け）およびET Open（コミュニティ向け）の各チャンネルにて、これらのルールの提供を開始しました。

新しいルールセットのダウンロード方法

この新しいルールセットの入手方法は、以前のバージョンのSuricataルールセットとほぼ同じです。

rules.emergingthreats.netからETOPENルールセットを手動でダウンロードする場合（curl、wget、またはお好みのWebブラウザを使用）、変更点はダウンロードするSuricataルールのバージョンを示すバージョン文字列のみです。例えば、wgetを使用してSuricata 7.0.3のemerging-all.rules.tar.gzファイルをダウンロードする場合、以下ようになります。

wget <http://rules.emergingthreats.net/open/suricata-7.0.3/emerging-all.rules.tar.gz>

ETPROをご利用の場合、wgetコマンドも少し変更されます：

wget [https://rules.emergingthreatspro.com/\[poincode here\]/suricata-7.0.3/etpro-all.rules.tar.gz](https://rules.emergingthreatspro.com/[poincode here]/suricata-7.0.3/etpro-all.rules.tar.gz)

一方、Suricata 7.0.3以降を実行しているsuricata-updateのユーザーは、次回suricata-updateを実行した際に、新しいルールセットが自動的に取得されます。もし何らかの理由でこれを避け、Suricata 5のルールセットを使い続けたい場合は、suricata-updateコマンドに--suricata-version 5.0.0というフラグを指定することをお勧めします。

Changes in the 7.0.3 ruleset

実際、この取り組みにおいては、当社の本番用「5/6」ルールセットに数多くの変更を加える必要がありました。Suricata 7.0.3で追加された重要な機能のおかげで、私たちは既存のルールを大幅に刷新し、この新しい製品へと移行させるという決断を下しました。なぜそのような判断に至ったのか、その理由を説明します。

OISFはSuricata 7.0.3において機能追加を行いました。その影響を受けるルールをHTTP/1とHTTP/2の双方で機能させるためには、既存のルール構文を修正する必要がありました。

HTTP/2

当社のテストおよび分析において、HTTPのバージョン間でHTTPヘッダー名の大文字・小文字の扱いに違いがあることに起因する、誤検知（False Positive）や検知漏れ（False Negative）の報告が多数寄せられました。こうした挙動を踏まえ、HTTP/2への対応強化は、今回のルール・フォーク（派生版作成）における最優先事項であり、ルール本体に対する最大の変更点となりました。

HTTP/2トラフィックへの対応を強化するためのルール内容の変換や修正は、9,500以上のルー

ルに及びました。以下は、どのルールをHTTP/2トラフィック対応に修正し、どのルールを「HTTP/1専用」とみなすかを決定する際に考慮された主な点です。

以下のいずれかの条件に該当する場合、約2,800のルールが「HTTP/1専用」とみなされました。

- authority疑似ヘッダーに大部分が置き換えられたHTTPヘッダー名「Host」を使用する検知ロジック（詳細は「Suri7におけるHTTP/2への対応」を参照）
- HTTP/1.xプロトコル固有のスティッキーバッファ（例: `http.request_line`、`http.response_line`、`http.start`、`http.protocol`）を含む検知ロジック
- 2015年以前に作成されたルールで、`http.header` または `http.start` 内で小文字への変換が必要となるHTTPヘッダー名を含む検知ロジックのために修正が必要だったもの
- SuricataがHTTP/2トラフィックに対してデータを格納しないスティッキーバッファ `http.start` の使用
- より具体的なバッファへ移行するには曖昧すぎた、バッファリングされないコンテンツマッチ（HTTP/2ではヘッダーやリクエストラインの他の部分（URIを含む）が圧縮されるため、バッファリングされないコンテンツはHTTP/2トラフィックにおいて検知漏れ（FN）を引き起こす可能性が高いため）

残りのHTTPルールについては、HTTP/2での使用に向けて修正を行う際、以下の対応をとりました。

- `http.header` または `http.header_names` スティッキーバッファでのコンテンツマッチを指定していたルールは、HTTP/1とHTTP/2の両方のネットワークトラフィックで正しくトリガーされるよう、`header_lowercase` 変換または `to_lowercase` 変換を使用するように変更されました。
- `http.header`、`http.header.raw`、および/または `http.header_names` 内で `bsize` や `startswith` キーワードを使用するルールに対し、`strip_pseudoheaders` 変換が適用されるようになりました。これにより、HTTP/1 および HTTP/2 トラフィックのいずれに対しても一貫したアラート生成が可能になります。

Rule Category Changes

生成されたアラートを分析する担当者が業務を行いやすいよう、私たちはルールを実用的かつフィルタリング可能なカテゴリに分類するよう努めています。今回のような大規模なルールの改訂は、ルールやそのカテゴリを再編成する好機となります。この最新のルールセットでは、いくつかの新しいカテゴリを導入する一方で、古いカテゴリを廃止し、それらに含まれていたルールを新規または既存のカテゴリに統合しました。

New categories:

FILE_SHARING:FILE_SHARING（ファイル共有）カテゴリには、ファイル共有プロトコルやサービスを検知するためのルールが含まれています。これらのルールは、ネットワークトラフィック内で観測されたファイル共有関連サービスについてアナリストに通知する「情報提供型」のルールと捉えることができます。例えば、Dropboxサービスに関連するトラフィックや、BitTorrentプロトコルに関連するWebサイトへのアクセスを検知するDNS/TLS SNIルールなどが挙げられます。

これらのサービスは（ネットワークやそのポリシーにもよりますが）通常、正当なものとみな

されます。しかし、これまで検知されたことのない（あるいは極めて稀だった）ルールが最近になってトリガーされた場合、それらは活動パターンの変化を示唆しており、異常の検知や調査のきっかけとして活用できます。新たなIDSアラートは活動パターンの変化を示しており、侵害の兆候や、さらなる調査を要する異常な活動である可能性があります。

REMOTE_ACCESS:

REMOTE_ACCESS（リモートアクセス）カテゴリは、さまざまなリモートアクセスプロトコルや、リモートアクセスサービスを提供するWebサイトへのアクセスを検知するものです。

FILE_SHARINGカテゴリと同様に、これらのサービスは通常、正当なものみなされます。しかし、これまで（あるいはほとんど）トリガーされたことのないルールがこのカテゴリで突然トリガーされた場合、それは活動パターンの変化を示しており、根本的な原因についてさらなる調査が必要となる可能性があります。

DYN_DNS:

簡単に言えば、Dynamic DNS（ダイナミックDNS）とは、頻繁に変更される可能性のある割り当て済みパブリックIPアドレスに対して、ユーザーがサブドメインを登録できるようにするサービスの一種です。企業環境においてDynamic DNSサービスが利用されるケースは極めて限定的ですが、一方で多くの脅威アクターは、フィッシングサイトや悪意のあるペイロードのホスティング、マルウェアのC2（コマンド&コントロール）など、さまざまな目的でDynamic DNSを好んで利用します。繰り返しになりますが、これらのルールは主に情報提供を目的としたものであり、行動パターンの変化を検知するために使用できます。また、なぜそのパターンが変化したのかについて、さらなる調査が必要になる場合もあります。

TA_ABUSED_SERVICES:

この新しいカテゴリは、脅威アクターによって悪用される傾向のあるサービスに関するルールを対象としています。例としては、脅威アクターの活動に悪用されるURL短縮サービス、特定のファイル共有サービス、Pastebinのようなサービスなどが挙げられます。このカテゴリでアラートがトリガーされたからといって、必ずしも脅威アクターの活動であるとは限りませんが、特に行動パターンや通常の活動状況に変化が見られる場合には、さらなる調査を行うべきです。

RETIRED:

ルールを「削除（DELETED）」カテゴリへ移動するという決定は、容易なものではありません。ある人にとっては古く時代遅れとみなされる脅威であっても、別の組織にとっては依然として監視し続けなければならない最悪の脅威である可能性があるからです。さらに、多くのペネトレーションテスト企業は、特定の脅威アクターのインジケーター、ツール、手法、戦術を模倣する「アドバーサリ・エミュレーション（攻撃者模倣）」サービスを提供しています。加えて、多くのサンドボックスサービスが、サンプルのネットワークトラフィックを分析するためにEmerging Threatsのルールセットを利用しています。場合によっては、サンプルがどのマルウェアファミリーに属するかを確実に特定する唯一の手段が、これらのIDSアラートであることもあります。ルールが「DELETED」カテゴリに移動されると、デフォルトで無効化されてしまいます。さらに、一度「DELETED」カテゴリに分類されたルールは、Emerging Threatsチームの公式方針として、もはやサポート対象外となります。すべての組織が「DELETED」カテゴリのルールリストを詳細に調査して自社にとって有効なルールを判断す

るわけではありませんし、誤検知やパフォーマンスの問題が発生した際にルールの保守や修正の責任を負いたいと思わないでしょう。

そこで私たちは解決策が必要だと判断し、「RETIRED（引退）」カテゴリを考案しました。このカテゴリに分類されるルールは、主要な「Actively Supported（積極的サポート対象）」カテゴリと、完全にサポート対象外となる「DELETED」カテゴリの中間に位置づけられます。

「RETIRED」カテゴリのルールは有効なままであり、引き続きアラートを生成しますが、そのサポートは「ベストエフォート（可能な範囲での対応）」となります。つまり、Emerging Threatsチームは、誤検知（False Positive）や検知漏れ（False Negative）といった検出上の問題の修正に合理的な努力を払いますが、将来的なルールの派生（フォーク）に伴うルール構文の更新などは行われません。その結果、Suricataの将来のバージョンにおけるパフォーマンスや互換性に影響が及ぶ可能性があります。

このようにすることで、古い脅威を検知するためにルールを有効にしておきたいユーザーをサポートしつつ、これらのルールを必要としないユーザーに対しては、「RETIRED」カテゴリ内の特定のルールのみを無効化したり、カテゴリ全体を無効化したりする選択肢を提供することが可能になります。廃止されたルールカテゴリ

以下のルールカテゴリは削除され、既存の他のルールカテゴリに統合されました。

- POLICY は INFO に統合されました。
- SCADA_SPECIAL は SCADA に統合されました。
- ICMP_INFO は ICMP に統合されました。

Suricata 4 形式のキーワードとスタイルガイドの変更

ETPRO および ET Open ルールは、10年以上にわたる研究、テスト、作成、サポートの成果であり、その数は10万件を超えています。長年にわたり、Suricataは機能やキーワードを拡充し、それらの新機能を活用するための新しい構文を導入するなど、進化を続けてきました。そのため、Suricata 7.0.3の新機能への対応作業に着手する前に、まずはルールセットの近代化と正規化を行い、使いやすさや「スタイル」に関する数多くの変更や方針の策定を行う必要がありました。具体的には、Suricata 5.0.0のルールセット内に、依然としてSuricata 4.0.0の構文を使用しているルールが多数存在していることを確認しました。そこで、ルールセットの近代化を大きく進めるとともに、新たに追加されるルールと既存のルール（レガシールール）との間で一貫性を確保するための取り組みを行いました。

ルールセットのこうした「改良」が完了したところで、可能な限り具体的なキーワードを使用することに重点が置かれました。例えば、次のような構文です。

```
http.header; content:"User-Agent|3a 20|Hello Word|0d 0a|";
```

このルール構文は、Emerging ThreatsチームがSuricata 4においてHTTPのUser-Agentフィールドに対するコンテンツマッチを行う際に使用しているものです。これと、以下のSuricata 5のルール構文を比較してみてください。

```
http.user_agent; bsize:10; content:"Hello Word";
```

`http.user_agent` スティッキーバッファを使用することで、User-Agent ヘッダー名の大文字・小文字を区別しないマッチングが可能になり、HTTP/1 と HTTP/2 の両方のトラフィックをより適切にサポートできるようになります。 `http.user_agent` に加え、Suricata 4 のキーワード

を置き換え、ルールセットをより最適化するために活用したキーワードを以下に挙げます。

- http.host
- http.content_type
- http.referer
- http.content_len
- http.server
- http.connnection
- http.location
- http.accept

Enforcement of the Suricata Style Guide Standards

最近公開された「Suricata Community Style Guide」のいくつかの要素も反映されました。これらはルールセットのパフォーマンスには影響しませんが、今回のルールセットのフォーク（派生版作成）は、実際に運用中のルールセットに対して数千もの個別の修正を行うことなく、ルールセットの大部分に及ぶ変更を加える好機となりました。そのため、削除対象とならなかったすべてのルールに対し、以下の変更が適用されました。

すべてのTCPおよびTCPアプリケーションプロトコル関連のルールにおいて、flowキーワードの記述が以下のように統一（正規化）されました：flow:established,[direction];ここで、[direction]（方向）はto_clientまたはto_serverのいずれかで指定します（例：flow:established,to_server;やflow:established,to_client;）。該当する場合、flowキーワードは常に、検出口ジックに関するキーワードの先頭に配置されます（通常はmsgキーワードの直後）。

flowbitsキーワードを使用するルールでは、同キーワードはflowキーワードの直後に記述されます。thresholdキーワードは検出口ジックの末尾に移動されました（例：reference（存在する場合）、classtype、sid、rev、metadataといったキーワードの直前に来る最後のキーワードとして配置）。可能な限り、depthキーワードはstartswith

キーワードに置き換えられました。bsizeキーワードは、スティッキーバッファ（sticky buffer）キーワードの宣言の後に移動されました。

for example:http.header_names; bsize:14; to_lowercase; content:"|0d 0a|hostname|0d 0a 0d 0a|";

Suricata 7.0.3の新機能

Suricata 5のドキュメントページとSuricata 7.0.3のドキュメントページを比較・対照することは可能ですが、それだけでは「Emerging Threatsルールセットの将来に関連する大きな変更点は何か？」という重要な疑問への答えにはなりません。

追加の変換機能

HTTP/1またはHTTP/2トラフィックに対する検知を共通して有効にするための主要な手法として、これまで strip_pseudo_headers、to_lowercase、header_lowercase といったキーワードを取り上げてきましたが、将来的には「ゲームチェンジャー」となり得る新しい変換オプションもいくつか登場しています。

変換キーワードを使用すると、Suricataによる評価が行われる前に、スティッキーバッファ（sticky buffer）内のペイロードデータを変更できます。これらのキーワードは組み合わせて使

用することが可能で、ルール内に記述された順序で評価されます。すでに紹介した変換機能に加え、Suricata 7.0.3では `url_decode` と `xor` が導入されました。

xor

XOR演算は、攻撃者がネットワークトラフィックを難読化するために頻繁に使用します。使用されるXORキーが固定（静的）である場合、xor変換にキーを指定することで、スティッキーバッファ（sticky buffer）の内容を変換し、他のSuricataキーワードとの照合に使用できるプレーンテキストデータを抽出することが可能です。その構文は以下のようになります。

```
[sticky buffer]; xor:"[xorkey]"; content:"ayy lmao";
```

[sticky buffer]ブレースホルダーを、XOR変換を適用するスティッキーバッファに置き換えてください。[xorkey]の値は、16進数でエンコードされている必要があります。以下は、`http.request_body`スティッキーバッファと、3バイトのXORキー「`AYY`」を使用したルールの例です。

```
alert http any any -> any any (msg:"ayy lmao in request body"; flow:established,to_server;  
http.method; content:"POST"; http.request_body; xor:"415959"; content:"ayy lmao"; sid:1;  
rev:1;)
```

そのルールは、このpcap内のHTTPリクエストボディで表されるネットワークトラフィックと照合されます。

url_decode

デフォルトでは、Suricataは `http.uri` スティッキーバッファ内のURLエンコードされた箇所を自動的にデコードします。これは他のスティッキーバッファには適用されない動作です。

`url_decode` 変換を追加することで、指定されたスティッキーバッファ内のデータがデコードされるようになります。例えば、「`+`」文字はスペースに変換され、「`%`」記号で始まる16進数エンコード値は対応するASCII文字にデコードされます。例として、次の値を考えてみましょう。

Cookie: %41%59%59

そして、それに`url_decode`変換を適用します：

```
alert http any any -> any any (msg:"ayy in cookie"; flow:established,to_server; http.method;  
content:"POST"; http.cookie; url_decode; content:"AYY"; sid:1; rev:1;)
```

このルールは、このpcapに示されているHTTP Cookieヘッダー内のネットワークトラフィックに対してトリガーされます。

New Rule Header Application Protocol Support

Suricataのルールでは、従来の `tcp`、`udp`、`icmp` といったオプションの代わりに、ルールヘッダー内でさまざまなネットワークアプリケーションプロトコルを使用できます。Suricata 7.0.3がサポートする新しいアプリケーション層プロトコルには、以下のようなものがあります。

- rfb
- rdp
- snmp
- bittorrent-dht
- tftp

New Protocol-Specific Keywords

Suricataのルールヘッダーで利用可能な新しいプロトコルオプションに加え、アプリケーション層プロトコル固有の新しいキーワードもいくつか追加されています。以下にその例をいくつか挙げます。

- RFB (Remote Frame Buffer – VNC) Keywords
- SIP Keywords
- SNMP Keywords
- HTTP2 Keywords

Feedback & Support

平素より格別のご愛顧とご支援を賜り、厚く御礼申し上げます。Emerging Threatsルールセットが今日に至るまで成功を収め続けているのは、ひとえにユーザーコミュニティの皆様との連携と、皆様による注視のおかげです。新たな脅威に関する報告はもちろん、既存のルールにおける誤検知（False Positive）や見逃し（False Negative）の指摘など、私たちは「目と耳」となったださるユーザーコミュニティの皆様に大きく支えられています。